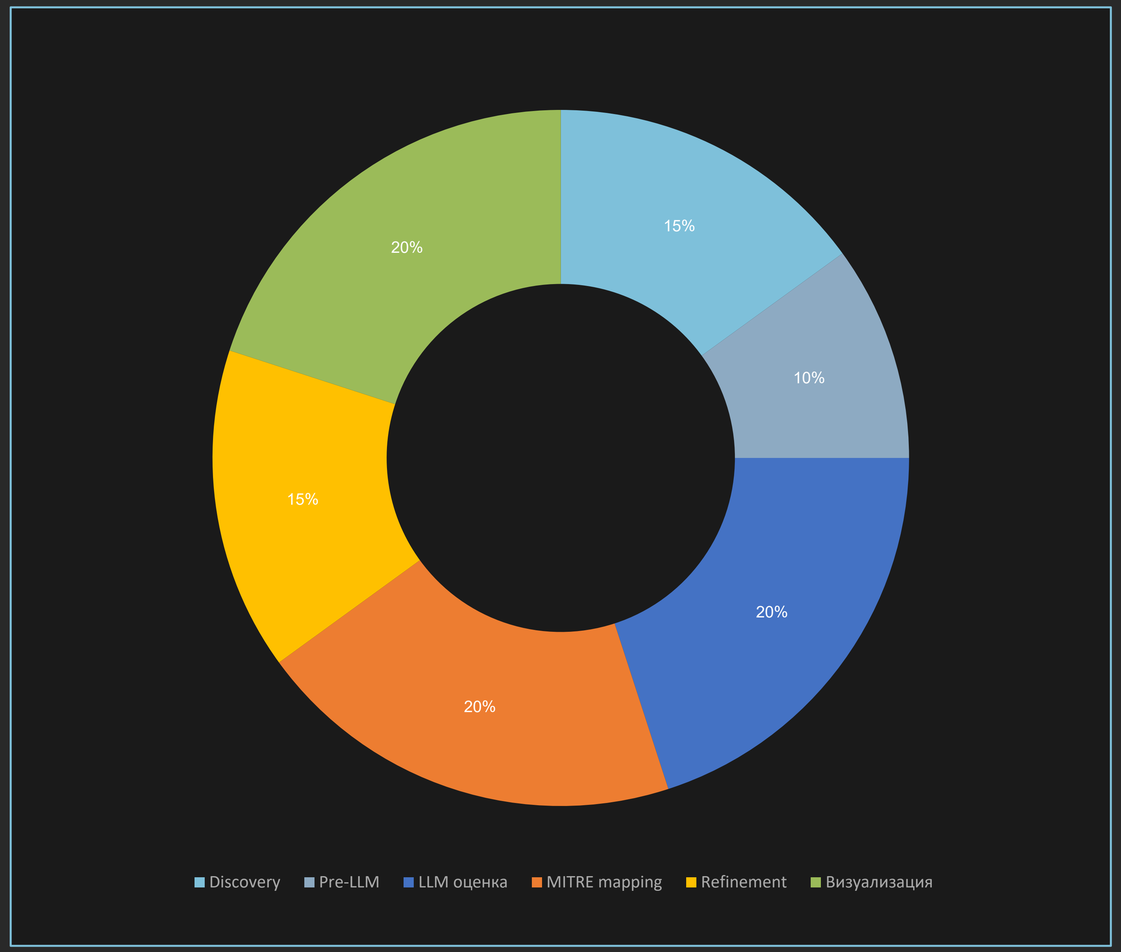
Автоматический мониторинг и классификация инструментов пентеста по MITRE ATT&CK

Этап 3: Пререлиз-чекап

Команда: Новосельский Д ▪ Коломийцев Н ▪ Толмачёв Н ▪ Ширинов А ▪ Игнатов Д

Структура презентации

- 1. Ключевые улучшения новой версии
- 2. Сбор данных и pre-LLM логика
- 3. Pipeline и обработка данных
- 4. LLM-оценка и MITRE-маппинг
- 5. Метрики качества и хранилище
- 6. Веб-интерфейс и визуализация
- 7. Рекомендации и дальнейшие шаги



Ключевые улучшения новой версии

Discovery offensive security инструментов

Улучшен поиск новых утилит, ослаблены фильтры по звёздам

Строгая LLM-оценка и MITRE confidence gate

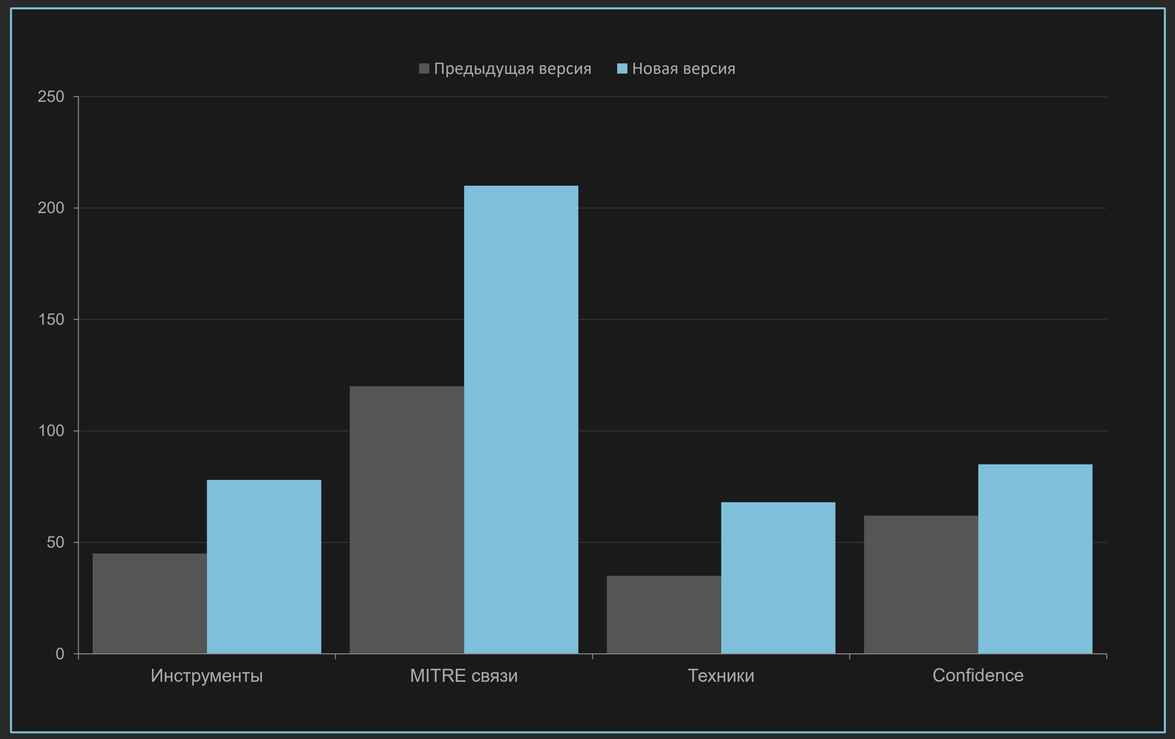
Консервативный промпт, threshold confidence ≥ 0.7

Structured LLM output через function calling

Предсказуемая JSON-схема вместо свободного текста

DuckDB — основное хранилище аналитики

Pipeline, assessments, mappings, history — всё в DuckDB



Главный фокус новой версии — качество данных и удобство анализа. Система стала лучше находить новые инструменты, которые ещё не набрали популярность, но уже могут быть полезны для пентеста.

Сбор данных и pre-LLM логика

Источники данных:

- GitHub API — поисковые срезы по свежести, языкам, query-группам
- Packet Storm — exploit-related материалы и ссылки
- RSS-ленты — новости и анонсы новых инструментов

Pre-LLM фильтрация:

- Отсечение документации, cheat sheets, walkthroughs
- Pre-LLM score: источник, свежесть, tool-сигналы, keywords
- Только релевантные кандидаты попадают в LLM assessment

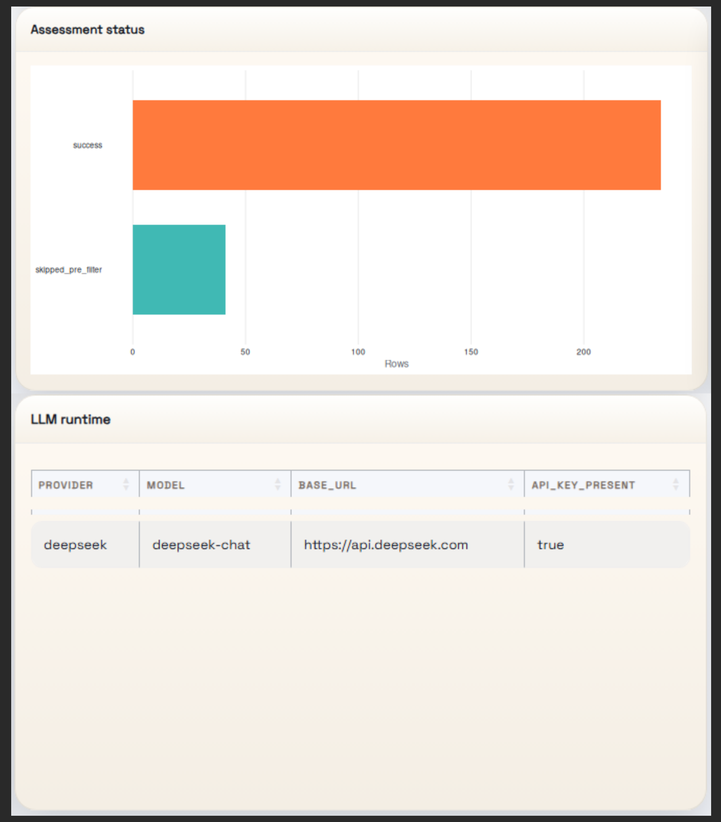


Схема потока данных

Sources → Raw candidates → Normalize → Pre-LLM score → LLM assessment queue

Сбор не завязан только на популярность. Новые offensive tools часто появляются с 0 звёзд и коротким README. Pre-LLM слой защищает от лишних затрат на API, отсекая очевидный мусор.

Как данные идут по pipeline

Pipeline — конвейер обработки: на входе разные источники, на выходе — подготовленные данные для веб-интерфейса.

collect
Сбор raw-кандидатов

normalize
Единая структура

assessment
LLM-оценка

refine_mitre
Доп. MITRE-кандидаты

visualize
Слой для Shiny

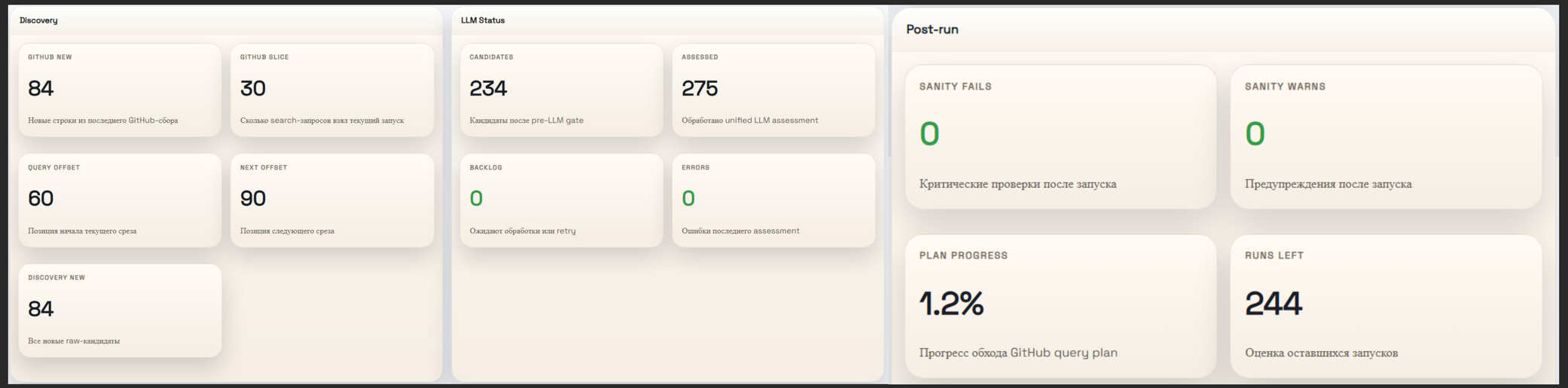
collect — GitHub API, Packet Storm, RSS дают сырые записи в разных форматах

normalize — приведение к общему виду: единые поля, типы, структура

assessment — LLM определяет: инструмент ли это, пишет описание, оценивает confidence, предлагает MITRE-связи

refine_mitre — retrieval-first refinement ищет пропущенные техники

visualize — сборка данных для Shiny: инструменты, MITRE matrix, метрики, сравнения



Как мы общаемся с LLM

DeepSeek как OpenAI-compatible provider

- Запросы через function calling
- Ответ — строгая JSON-схема
- Провайдер заменяемый

Structured output поля:

- is_relevant — релевантность записи
- summary_ru — русское описание
- confidence — уверенность модели
- mitre_classifications — связи с техниками

```
{
  "model": "deepseek-chat",
  "messages": [
    {
      "role": "system",
      "content": "Classify offensive security tools and map them to MITRE ATT&CK."
    },
    {
      "role": "user",
      "content": "Tool: example-c2. Supports agent callbacks over HTTP and remote command execution."
    }
  ],
  "tools": [
    {
      "type": "function",
      "function": {
        "name": "unified_tool_assessment",
        "parameters": {
          "type": "object",
          "properties": {
            "is_relevant": { "type": "boolean" },
            "entity_type": { "type": "string" },
            "name": { "type": "string" },
            "overall_confidence": { "type": "number" },
            "mitre_classifications": { "type": "array" }
          },
          "required": ["is_relevant", "entity_type", "name"]
        }
      }
    }
  ]
}
```

Поток данных через LLM

Normalized candidate → **LLM function call** → Structured JSON → Assessment table → MITRE mappings table

← Все таблицы в DuckDB

Архитектура не жёстко привязана к одному поставщику. При необходимости можно заменить provider на любой OpenAI-compatible endpoint.

LLM output и MITRE-маппинг

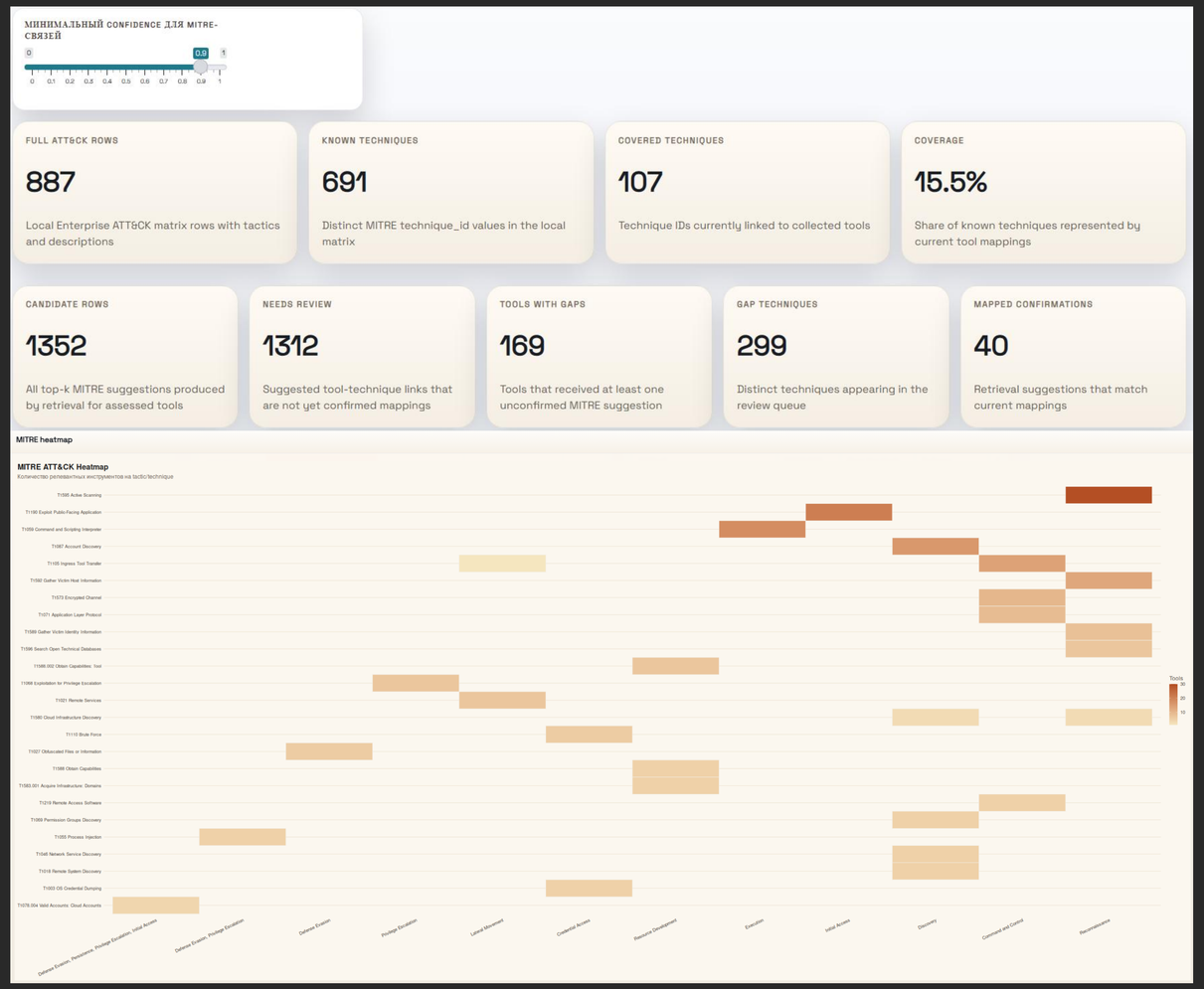
Что возвращает LLM:

- Релевантность (is_relevant)
- Тип сущности (tool, framework, scanner)
- Русское описание (summary_ru)
- Confidence score (0.0 – 1.0)
- MITRE classifications — массив связей

Принципы MITRE-маппинга:

- Техника назначается только при явных признаках
- Лучше пустой список, чем угадывание
- Confidence threshold для финальной матрицы: 0.7
- Retrieval-first refinement — предложения для review

Модель может начать угадывать общие техники (например, Reconnaissance). Строгий промпт и confidence gate защищают от этого.



Метрики качества: pre-LLM и post-LLM

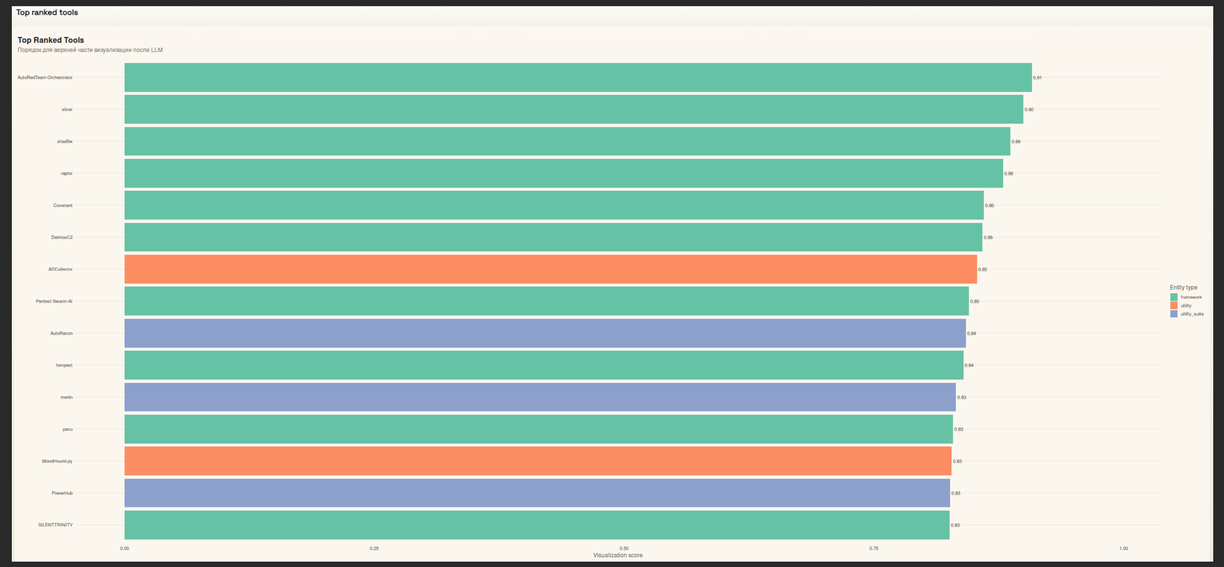
Метрика	Что измеряет	Этап
Pre-LLM score	Источник, свежесть, tool-сигналы	Pre-LLM
Confidence score	Уверенность LLM-оценки	Post-LLM
Detail score	Полнота и полезность описания	Post-LLM
MITRE score	Количество и качество связей	Post-LLM
Entity priority	Приоритет типа сущности	Composite

Composite score (итоговый ranking)

visualization_score =

pre_llm_score + confidence_score + detail_score

+ mitre_score + entity_priority



На верху рейтинга оказываются не просто популярные репозитории, а инструменты, которые выглядят полезными, понятными и хорошо размеченными.

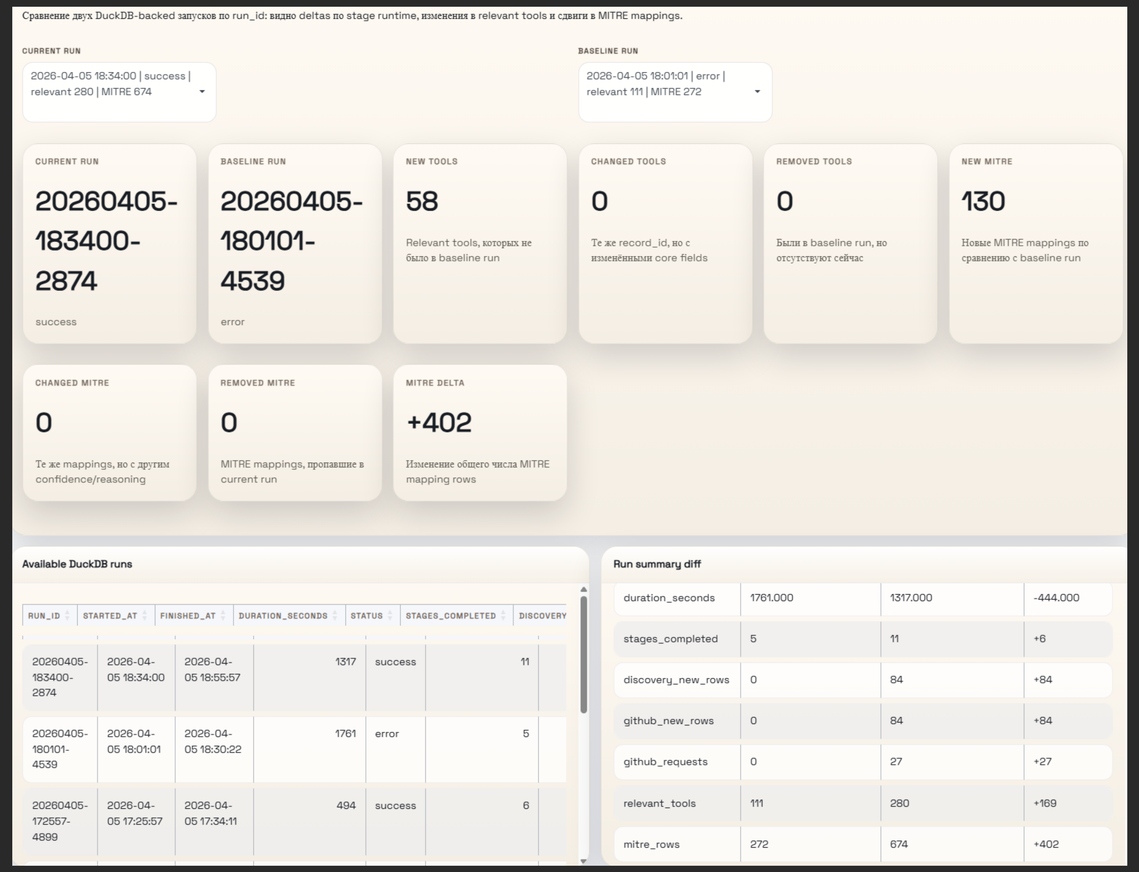
DuckDB: основное хранилище

DuckDB — primary source of truth

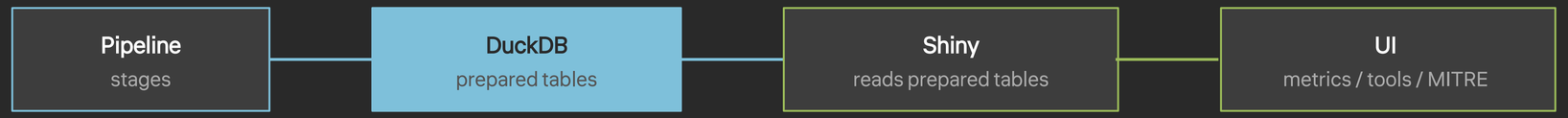
- Таблицы pipeline: candidates, queue, status
- Результаты LLM assessment
- MITRE mappings и refinement queue
- Visualization layer для Shiny
- История запусков (run_id)
- Run comparison между запусками

RDS — вспомогательный кэш

- Быстрый локальный cache для R-операций
- Не основной слой архитектуры



Архитектура хранения



Overview: главная картина

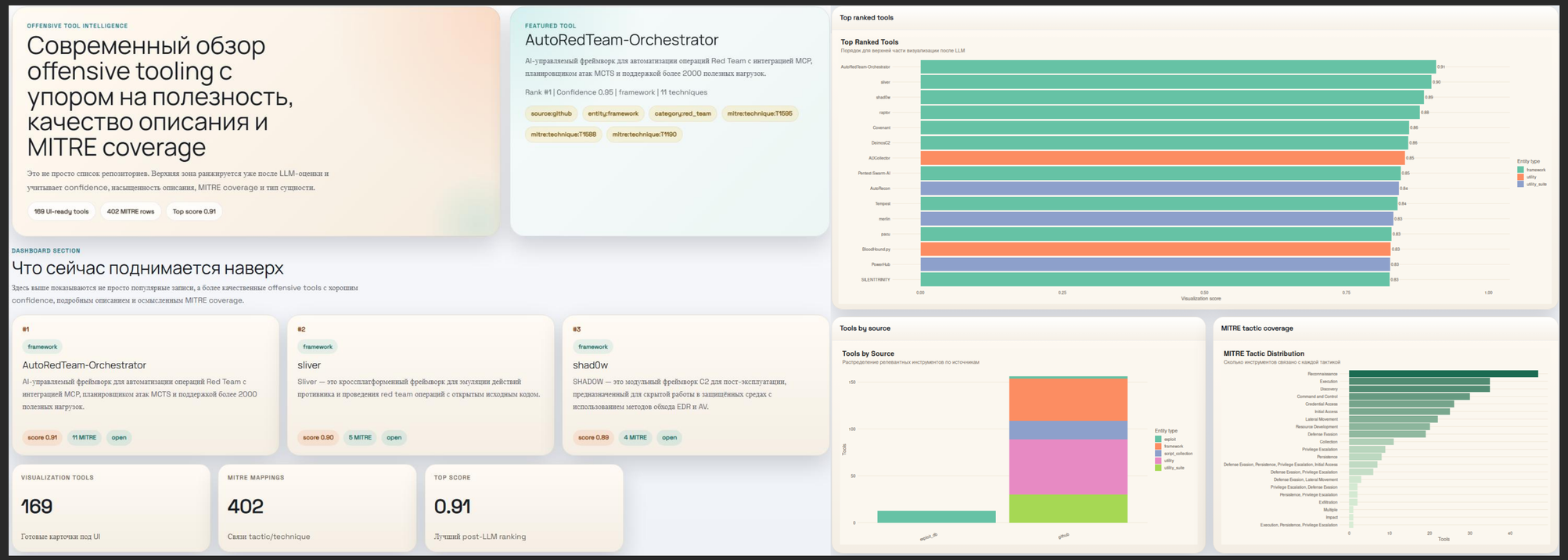
Ключевые метрики Overview

Visualization tools
Инструменты, прошедшие pipeline

MITRE mappings
Связи tool → technique

Top score / Featured tool
Лучший инструмент по ranking

Tactic coverage
Распределение по MITRE tactics



Overview — стартовый экран. Данные берутся из подготовленного visualization layer в DuckDB, а не из raw-кандидатов.

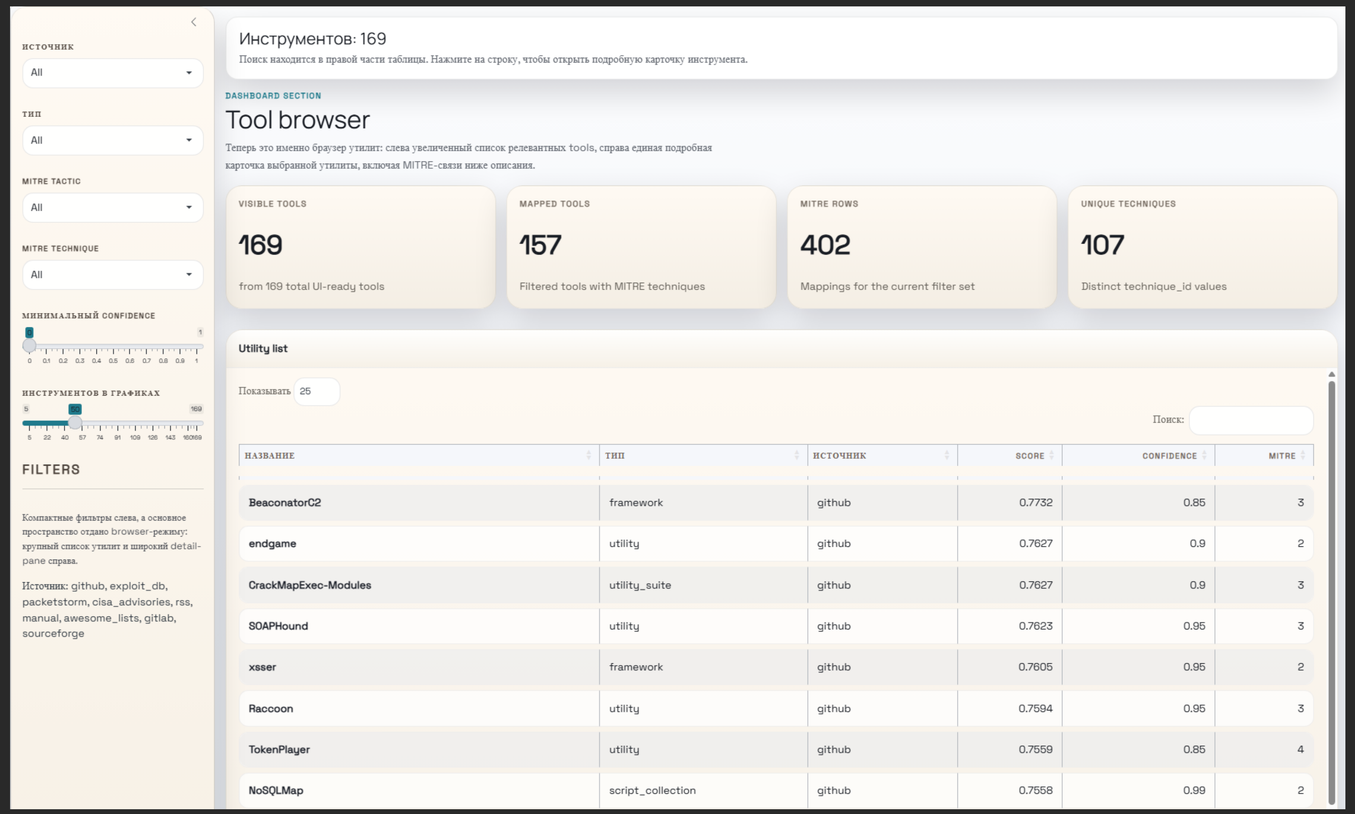
Tools: рабочий каталог

Основная вкладка для просмотра инструментов

- **Боковые фильтры** — по источнику, типу, MITRE-технике
- **Строка поиска** — быстрый поиск по названию
- **Сортировка** — по score, confidence, дате

Колонки таблицы:

- Название инструмента
- Тип (tool, framework, scanner...)
- Источник (GitHub, Packet Storm...)
- Score — composite ranking
- Confidence — уверенность LLM
- MITRE coverage — количество связей



Клик по строке → подробная карточка инструмента

Данные в таблице приходят из подготовленного visualization layer, который формируется после LLM и сохраняется в DuckDB.

Tools: подробная карточка инструмента

Модальное окно — один клик по строке

Основная информация:

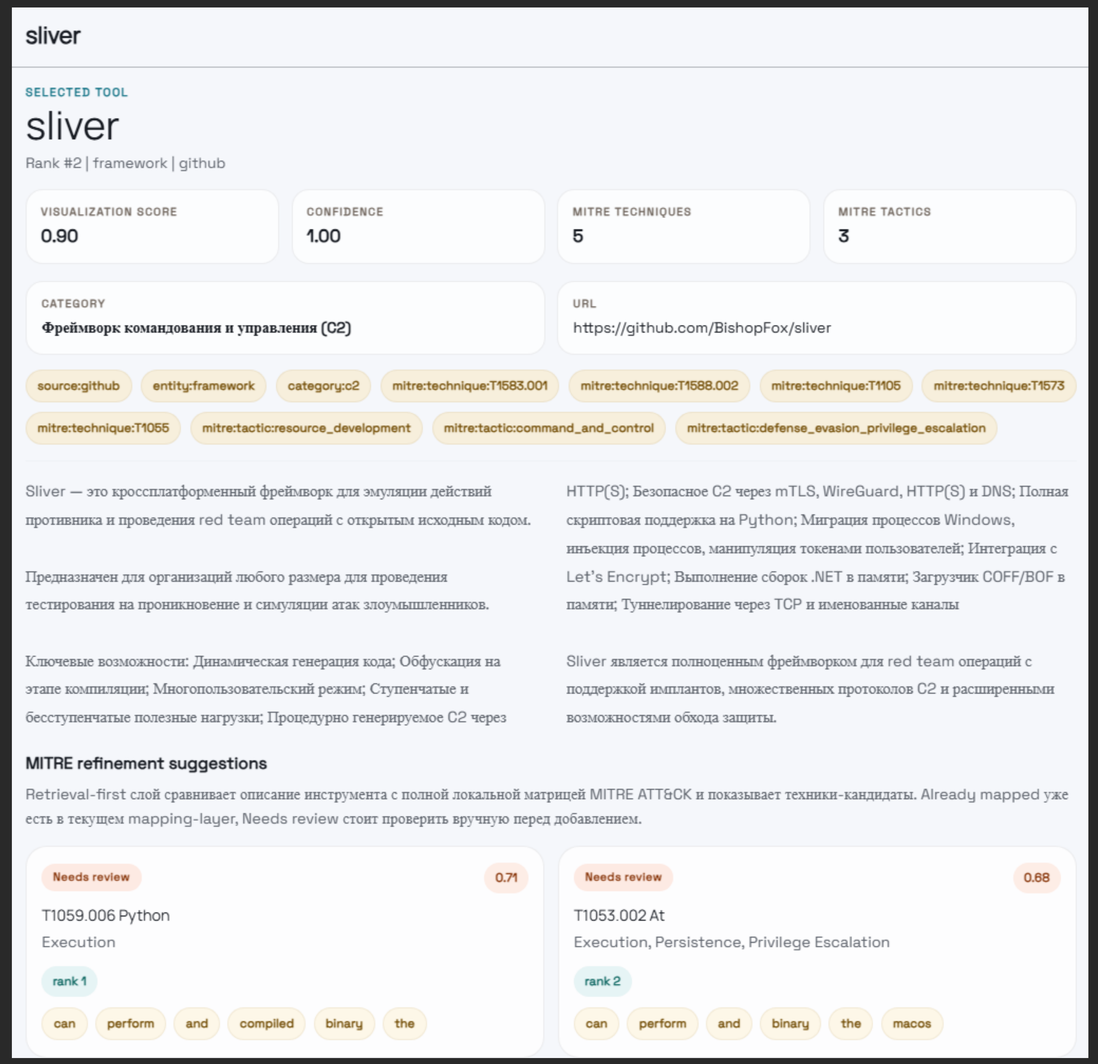
- Русское описание (summary_ru)
- Источник и URL на оригинальный проект
- Тип инструмента

Метрики качества:

- Score — composite ranking
- Confidence — уверенность LLM-классификации

MITRE покрытие:

- Techniques — конкретные техники ATT&CK
- Tactics — тактики (Reconnaissance, C2...)
- Таблица связей: technique id, название, tactic, confidence



MITRE Matrix

Визуализация MITRE ATT&CK

- **Связи tool → tactic → technique**
- **Heatmap** — плотность покрытия по тактикам

(где больше инструментов — ярче ячейка)

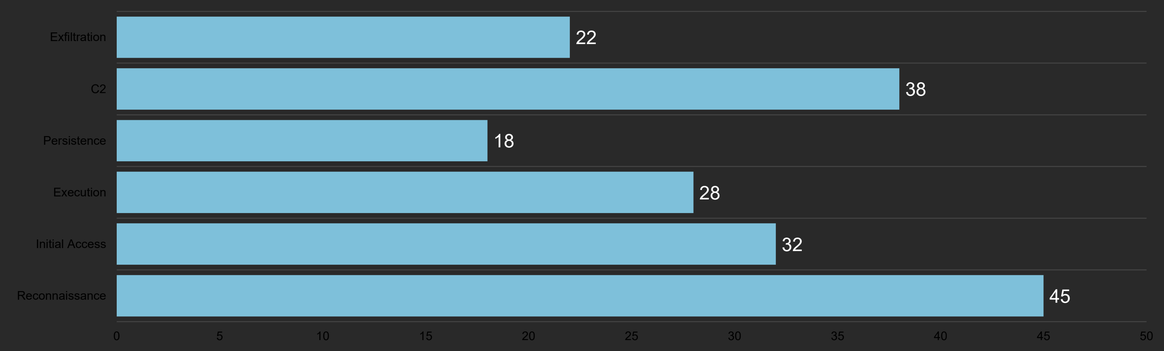
- **Matrix rows** — конкретные строки маппинга

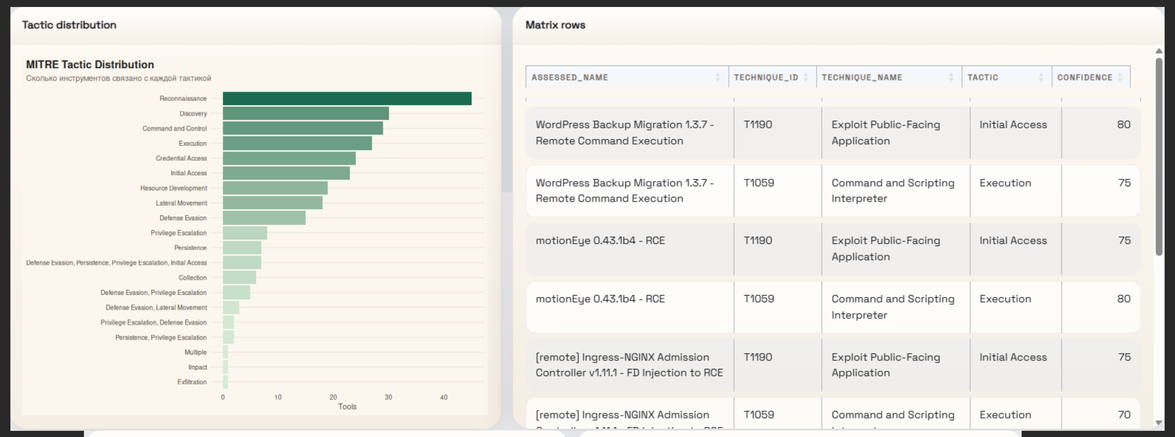
(один инструмент = несколько строк)

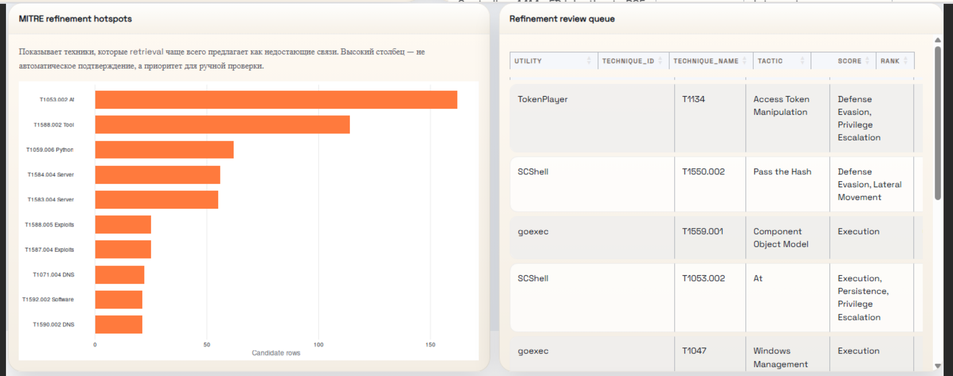
Confidence slider

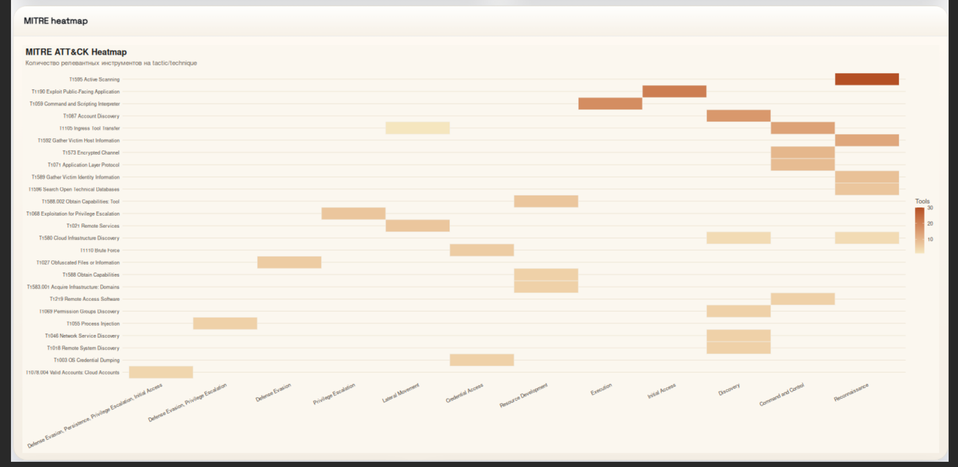
- Управляет строгостью отображения
- Высокий порог = только самые уверенные связи
- Данные из post-LLM таблиц DuckDB

Пример распределения coverage









Refinement Queue

Retrieval-first refinement

- Сравнивает описание инструмента с локальной MITRE matrix
- Предлагает похожие техники, которые LLM могла пропустить
- Если техника уже есть в mapping — считается покрытой
- Если нет — попадает в очередь review

Важно: это не автоматическое подтверждение

- Список гипотез для проверки аналитиком
- Hotspots — техники, часто предлагаемые как gaps

Следующий шаг:

- Сохранять решения аналитика в DuckDB
- confirmed / rejected / needs_more_context

Возможные решения аналитика

confirmed | rejected | needs_more_context

Refinement review queue

UTILITY	TECHNIQUE_ID	TECHNIQUE_NAME	TACTIC	SCORE	RANK
TokenPlayer	T1134	Access Token Manipulation	Defense Evasion, Privilege Escalation	1.273711382038507	1
SCShell	T1550.002	Pass the Hash	Defense Evasion, Lateral Movement	0.7439477026399566	1
goexec	T1559.001	Component Object Model	Execution	0.7387540477335348	2
SCShell	T1053.002	At	Execution, Persistence, Privilege Escalation	0.7342818728565026	2
goexec	T1047	Windows Management Instrumentation	Execution	0.7280058003571148	3
goexec	T1053.002	At	Execution, Persistence, Privilege Escalation	0.7277907949630145	4
pacu	T1053.002	At	Execution, Persistence, Privilege Escalation	0.7265667515939436	1
Acacium-PostEx-Toolkit	T1059.006	Python	Execution	0.7258376701585452	1
Raccoon	T1595.002	Vulnerability Scanning	Reconnaissance	0.7256852789557215	1
CEPHALUS_HUNTER_RDP_DETECTOR	T1563.002	RDP Hijacking	Lateral Movement	0.7245382595838266	1

Showing 1 to 10 of 20 entries

Previous 1 2 Next

Pipeline: контроль выполнения

Discovery

Сбор новых кандидатов, GitHub slices, свежие репозитории

LLM Status

Очередь, assessment, backlog, errors

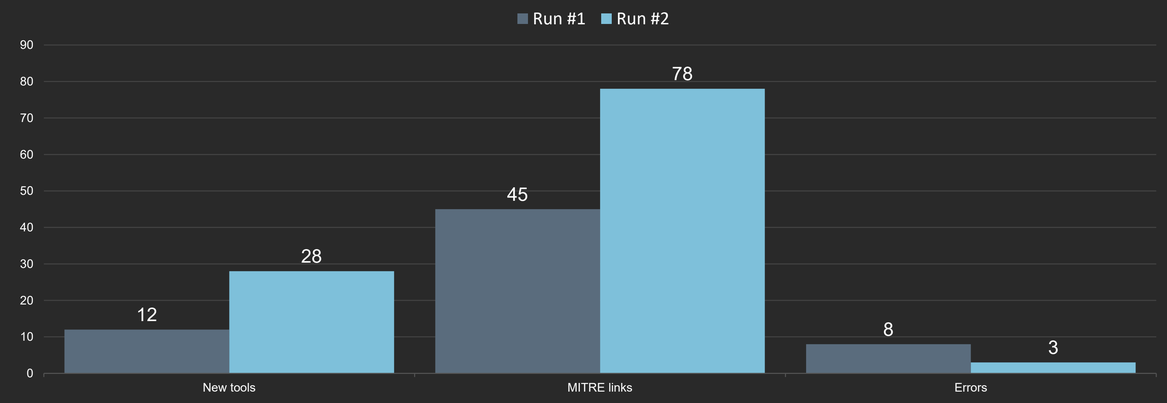
Coverage

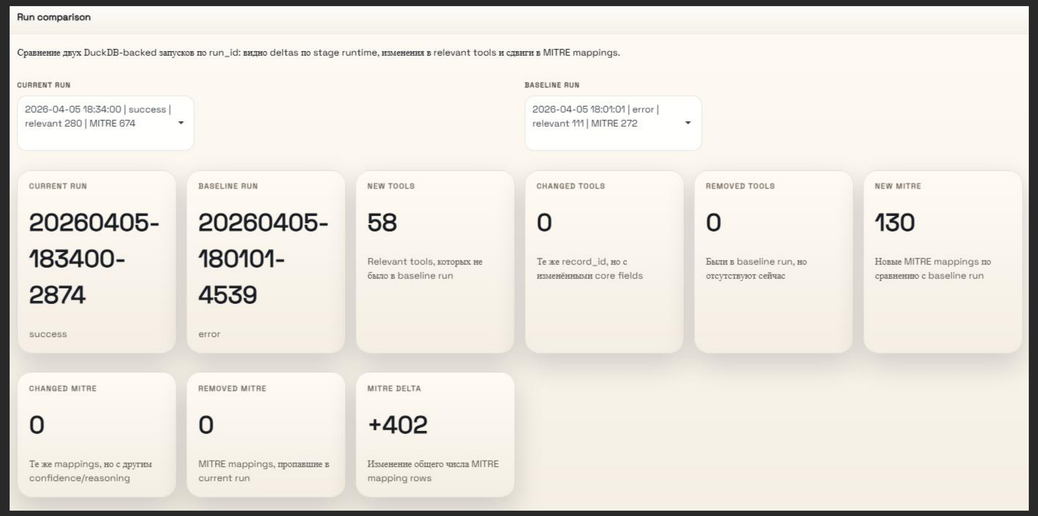
Relevant tools и MITRE rows после LLM

Post-run

Sanity fails, warnings, run comparison

Run comparison — изменения между запусками





Как данные попадают в веб

Данные не появляются в Shiny сразу после сбора. Сначала они проходят полный pipeline.

Sources
GitHub / RSS / Packet Storm

→

Pipeline
collect → normalize → assess

→

DuckDB
prepared tables

→

Shiny
reads prepared tables

→

UI: Overview / Tools / MITRE / Pipeline

Raw-кандидаты в UI не попадают

Это снижает шум: нет документации, списков ссылок, новостей и нерелевантных записей в интерфейсе

Available DuckDB runs

RUN_ID	STARTED_AT	FINISHED_AT	DURATION_SECONDS	STATUS	STAGES_COMPLETED	DISCOVER
20260405-183400-2874	2026-04-05 18:34:00	2026-04-05 18:55:57	1317	success	11	
20260405-180101-4539	2026-04-05 18:01:01	2026-04-05 18:30:22	1761	error	5	
20260405-172557-4899	2026-04-05 17:25:57	2026-04-05 17:34:11	494	success	6	

Run summary diff

duration_seconds	1761.000	1317.000	-444.000
stages_completed	5	11	+6
discovery_new_rows	0	84	+84
github_new_rows	0	84	+84
github_requests	0	27	+27
relevant_tools	111	280	+169
mitre_rows	272	674	+402

MITRE mappings diff

CHANGE_TYPE	ASSESSED_NAME	TECHNIQUE_ID	TECHNIQUE_NAME	TACTIC	BASELINE_CONFIDENCE
new	Acacium-PostEx-Toolkit	T1021	Remote Services	Lateral Movement	
new	Acacium-PostEx-Toolkit	T1055	Process Injection	Defense Evasion, Privilege Escalation	
new	Acacium-PostEx-Toolkit	T1078	Valid Accounts	Defense Evasion, Persistence, Privilege	

Pipeline sanity checks

RUN_ID	CHECK_NAME	STATUS	SEVERITY	OBSERVED_VALUE	EXPECTED_VALUE	DETAILS
20260405-183400-2874	normalized_non_empty	pass	critical	275		
20260405-183400-2874	normalized_record_id_unique	pass	critical	0		

Stage-by-stage diff

normalize		success	
preflight_assessment	success	success	1523
preflight_export_webapp	success	success	0
preflight_refine_mitre	success	success	142
preflight_visualize	success	success	2

Showing 1 to 8 of 11 entries

Previous 1 2 Next

Relevant tools diff

CHANGE_TYPE	ASSESSED_NAME	SOURCE	ENTITY_TYPE	BASELINE_CONFIDENCE_SCORE	CU
new	Acacium-PostEx-Toolkit	github	script_collection		
new	AD-Attack-Toolkit	github	utility_suite		
new	ADCollector	github	utility		
new	ADHunt	github	script_collection		
new	Atomic-Red-Team-C2	github	framework		
new	AutoRecon	github	utility_suite		

Recent GitHub search requests

EXECUTED_AT	REQUEST_INDEX	QUERY_FAMILY	SEARCH_SORT	SEARCH_PAGE	RETURNED_ROWS
2026-04-05 18:36:57	27	star_band_discovery	best-match	1	
2026-04-05 18:36:57	26	rolling_windows	best-match	1	
2026-04-05	25	recent_discovery	best-match	1	

Batch pipeline runs

RUN_INDEX	STARTED_AT	DURATION_SECONDS	GITHUB_NEW_ROWS	GITHUB_REQUEST_OFFSET
	No batch summary available yet			

Showing 1 to 1 of 1 entries

Previous 1 Next

Рекомендации и дальнейшие улучшения

1. **Ручная модерация Refinement Queue**

   Подтверждение/отклонение связей прямо в интерфейсе аналитиком

2. **Сохранение решений аналитика в DuckDB**

   confirmed / rejected / needs_more_context — для аудита и повторного использования

3. **LLM Observability — отдельная вкладка**

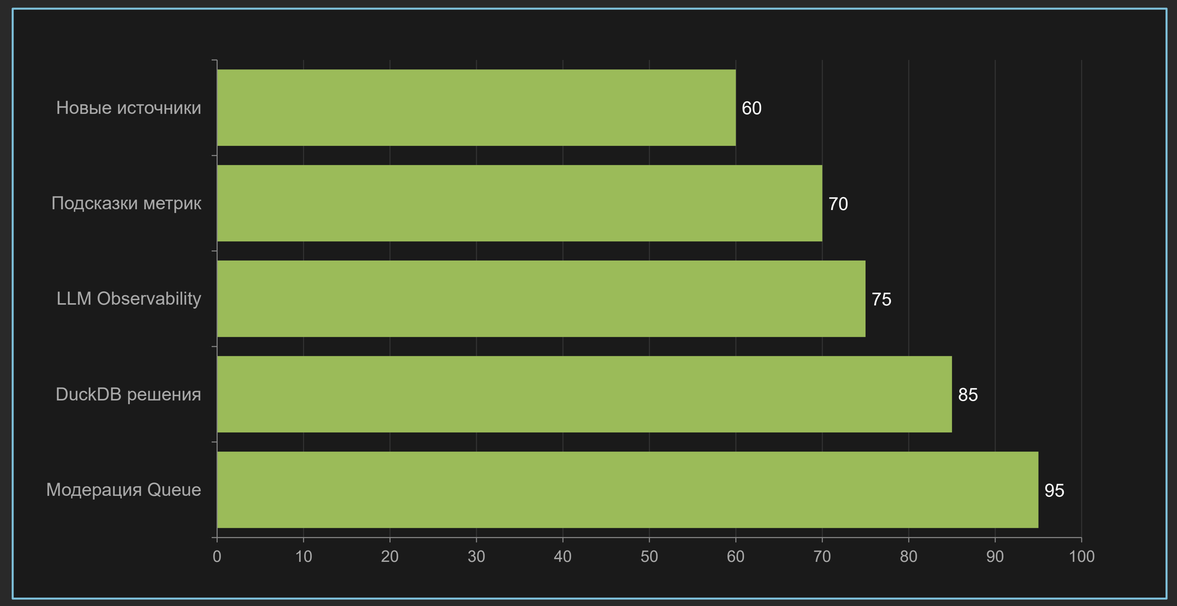
   Latency, retry count, error types, provider, model, стоимость обработки

4. **Подсказки по метрикам в интерфейсе**

   Что означает pre-LLM score, confidence, MITRE rows, backlog, sanity warnings

5. **Расширение источников discovery**

   Exploit-DB, HackerOne, новые RSS-ленты специализированных ресурсов



Спасибо за внимание

Команда: Новосельский Д ▪ Коломийцев Н ▪ Толмачёв Н ▪ Ширинов А ▪ Игнатов Д

Автоматический мониторинг и классификация инструментов пентеста по MITRE ATT&CK